

Risk 1: Weak Multi-Factor Authentication Coverage for Critical Applications

1. Category: Access Control / Identity and Access Management
2. Priority: High
3. Likelihood: High
4. Impact: Unauthorized access to sensitive systems using stolen credentials.
5. Business Impact: Data leakage, fraud risk, compliance observations, operational disruption.
6. Risk ID: RSK-ISO-001
7. Risk Owner: Head of IT Security
8. Related Asset / Process: HRMS, Payroll, ERP login systems
9. Threat: Credential theft / account compromise
10. Vulnerability: Absence of MFA for several privileged and business-critical users
11. Existing Control:
12. Inherent Risk Rating: High
13. Residual Risk Rating:
14. Compliance Impact: Possible non-conformance with access control expectations
15. Treatment Plan: MFA rollout across all critical business applications
16. Review Frequency: Monthly
17. Target Date: 2026-04-20
18. Acceptance Decision:
19. Control Maturity Score: 2/5
20. Mitigation:
21. Enforce MFA for all admin and sensitive business users.
22. Review inactive and stale accounts.
23. Implement suspicious login alerting.

Risk 2: Incomplete Log Monitoring for Security Events

1. Category: Logging and Monitoring / Operations Security

2. Priority:
 3. Likelihood: Medium
 4. Impact: Delayed detection of suspicious activity, incomplete investigations, weak incident response.
 5. Business Impact:
 6. Risk ID: RSK-ISO-002
 7. Risk Owner: SOC Lead
 8. Related Asset / Process: SIEM monitoring process
 9. Threat:
 10. Vulnerability: Several systems are not forwarding logs consistently to the central monitoring platform
 11. Existing Control: SIEM enabled for selected servers only
 12. Inherent Risk Rating: Medium
 13. Residual Risk Rating:
 14. Compliance Impact: Monitoring gaps may affect audit readiness and security investigations
 15. Treatment Plan:
 16. Review Frequency: Quarterly
 17. Last Review Date: 2026-03-01
 18. Next Review Date:
 19. Detection Coverage: 68%
 20. Mitigation:
 21. Identify log source gaps across critical systems.
 22. Integrate endpoints, databases, and network devices into SIEM.
 23. Define use cases and alert thresholds for priority events.
-

Risk 3: Third-Party Vendor Access Without Formal Review

1. Category: Third Party / Supplier Security
2. Priority: High

3. Likelihood:
4. Impact: Vendors may retain unnecessary access, leading to unauthorized exposure or misuse of business data.
5. Business Impact: Data confidentiality concerns, compliance observations, vendor-related security incidents.
6. Risk ID:
7. Risk Owner:
8. Related Asset / Process: Vendor remote access to support systems
9. Threat: Misuse of third-party access or compromise of vendor credentials
10. Vulnerability:
11. Existing Control: Manual spreadsheet-based tracking
12. Inherent Risk Rating: High
13. Residual Risk Rating: High
14. Compliance Impact:
15. Treatment Plan: Formalize vendor onboarding/offboarding and quarterly access review
16. Review Frequency:
17. Target Date: 2026-05-01
18. Acceptance Decision: Pending
19. Vendor Criticality: Critical
20. Mitigation:
21. Maintain approved vendor access registry.
22. Enforce periodic access recertification.
23. Disable inactive vendor accounts immediately after engagement closure.